MIGRATION WORKBENCH

ตรวจข้อมูลหลังย้ายระบบแบบมีหลักฐานต่อ record และพร้อมให้คนอนุมัติ

NFR และความปลอดภัย

รหัสเอกสาร	MVW-DOC-03
ฉบับ	0.1
วันที่	2026-10-08
สถานะ	ร่างเพื่อพิจารณา

เอกสารภายในฉบับร่าง — ใช้ประกอบการพัฒนาและดูแลระบบ

สารบัญ

1. ข้อกำหนดที่วัดได้

2. Security controls

3. ความเสี่ยงที่ยังเปิดอยู่

4. Privacy/PDPA

5. Observability

6. Backup/DR

การอนุมัติ

แหล่งข้อมูล

Migration Validation Workbench — NFR และความปลอดภัย

1. ข้อกำหนดที่วัดได้

ID	หมวด	ข้อกำหนด	ค่าเป้าหมาย/ค่าในโค้ด	หลักฐาน
NFR-01	Performance	ขนาด request สูงสุด	20 MB (`MAX_BODY_BYTES`) → 413	`server.py` , `test_size_guard`
NFR-02	Performance	ขนาด dataset	≤ 200,000 แถว, ≤ 500 คอลัมน์ → 413	`input_contract.py` , `test_dataset_shape_limit_returns_413`
NFR-03	Performance	fuzzy matching มีขอบเขต	candidate ≤ 5 ต่อ record (ค่าเริ่มต้น 3), threshold 0.90, พิจารณา ≤ 2,000 แถว	`fuzzy.py` , `test_fuzzy_configuration_can_be_disabled_and_is_bounded`
NFR-04	Performance	เวลาตรวจ 200,000 แถว บน laptop ทั่วไป	≤ 60 วินาที **[สมมติฐาน]**	ยังไม่วัด
NFR-05	Determinism	input + configuration เดิม → ผลและ fingerprint เดิม	audit package เสถียร	`test_package_is_stable_and_omits_raw_evidence_values` , `test_configuration_fingerprint_is_order_independent`
NFR-06	Availability	ใช้งาน offline ได้ทั้งหมด	ไม่มี outbound call	README "สิ่งที่ยังไม่ทำ"
NFR-07	Security	API ไม่ถูกเข้าถึงจาก network โดยไม่ตั้งใจ	bind loopback; non-loopback ต้อง `--allow-remote`	`cli.py` , `test_cli_bind.py`
NFR-08	Security	CORS	เฉพาะ origin localhost:3000 หรือ `MVW_ALLOWED_ORIGINS` ; `allow_credentials=False` ; methods GET/POST/OPTIONS	`test_cors_allows_only_local_origins`
NFR-09	Security	XLSX ไม่ทำให้ memory ระเบิด	ปฏิเสธ cell reference เกิน 16,384 คอลัมน์ และ part ที่ขยายเกิน 100 MB	`test_column_reference_beyond_excel_limit_is_rejected` , `test_corrupted_part_is_a_dataset_error`
NFR-10	Security	path traversal ใน `/fixtures`	404 เมื่ออยู่นอก sample root	`test_fixture_route_blocks_traversal`
NFR-11	Security	ชื่อไฟล์ไม่มี directory part	ตัดส่วน path ทิ้ง	`test_inspect_strips_directory_parts_from_filenames`
NFR-12	Security	SQL injection ผ่านชื่อคอลัมน์	quote + escape `"` , ปฏิเสธ control char และยาวเกิน 128	`test_sql_generation.py`
NFR-13	Privacy	audit package ไม่มีค่า raw	`raw_values_included: false`	`test_audit.py`
NFR-14	Privacy	redacted export ไม่แก้ผลต้นฉบับ	deep-copy	`test_redaction_does_not_mutate_reconciliation_result`
NFR-15	Usability	match rate ไม่แสดง 100% เมื่อยังมี exception	`_display_rate`	`test_match_rate_is_not_100_with_exceptions`
NFR-16	Accessibility	control มี label, row เลือกด้วยคีย์บอร์ดได้	`aria-label` , `tabIndex` , Enter/Space	`apps/web/app/page.tsx`

2. Security controls

- ไม่มี auth โดยเจตนา (local-only prototype) — ชดเชยด้วย loopback bind + CORS จำกัด
- request size guard ทำงานก่อน parse JSON
- error ตอบเป็น JSON `{"error": ...}` แบบมีโครงสร้าง ไม่คืน stack trace
- dataset error แยก 400 (รูปแบบผิด) และ 413 (ใหญ่เกิน)
- normalization profile ที่ไม่รู้จักทำให้ request ล้มแบบ fail-closed

3. ความเสี่ยงที่ยังเปิดอยู่

ID	ความเสี่ยง	ระดับ	ข้อเสนอ
R-01	ถ้า operator ใช้ `--allow-remote` ใครก็อัปโหลด/อ่านผลได้ เพราะไม่มี auth	สูงเมื่อเปิด	ห้ามใช้กับข้อมูลจริงจนมี access control (`deploy/README.md`)
R-02	CSV ถูก parse ทั้งไฟล์ก่อนตรวจ row cap (มี 20 MB กันไว้)	ต่ำ	stream-count ถ้าขยาย body limit (UPGRADE-PLAN P1)
R-03	`review_statuses` ไม่ตรวจว่า key ตรงกับ evidence id และไม่จำกัดขนาด	ต่ำ	UPGRADE-PLAN P2
R-04	dev server ของ Next.js อาจรับการเชื่อมต่อจากเครื่องอื่น **[ต้องยืนยัน]** — แต่ browser ระยะไกลจะเรียก API ที่ 127.0.0.1 ของตัวเอง จึงไม่เข้าถึงข้อมูล	ต่ำ	ระบุ `-H 127.0.0.1` ในคู่มือ pilot
R-05	uvicorn access log (`log_level=info`) บันทึก path และ IP แต่ไม่บันทึก body	ต่ำ	ยืนยันว่าไม่มี log payload ใน pilot **[ต้องยืนยัน]**

4. Privacy/PDPA

- เครื่องมือประมวลผลข้อมูลส่วนบุคคลของลูกค้า (ชื่อ เบอร์ เลขผู้เสียภาษี ที่อยู่) บนเครื่อง operator เท่านั้น ไม่เก็บถาวร
- ผู้ควบคุมข้อมูลคือเจ้าของข้อมูล/ลูกค้าของ operator; operator ต้องได้รับอนุญาตก่อนนำข้อมูลมาตรวจ **[สมมติฐาน]**
- brief กำหนดให้ trial ใช้ข้อมูลที่ลบข้อมูลระบุตัวตนแล้ว และห้ามข้อมูลจริงใน fixtures, logs, Git
- ไฟล์ที่ดาวน์โหลด: audit package ไม่มีค่า raw; Markdown report (`makeReport` ใน `apps/web/app/page.tsx`) ไม่มีค่า field แต่ **แสดงค่า key ของทุก evidence** ในหัวข้อ "Review status" และระบุ "Export mode: field-profile redacted" — ถ้า key เป็นเลขผู้เสียภาษีหรือเลขบัตร ค่านั้นจะติดไปกับ report (R-06)

ID	ความเสี่ยงเพิ่มเติม	ระดับ	ข้อเสนอ
R-06	report แสดงค่า key ดิบ ขณะที่ป้ายบอกว่า redacted	กลาง	hash/mask key ใน report หรือเปลี่ยนข้อความป้าย **[ต้องยืนยัน]** ว่าตั้งใจ

5. Observability

- `/api/health` สำหรับตรวจว่า API ทำงาน
- uvicorn log ระดับ info; ไม่มี metrics หรือ telemetry (สอดคล้องกับ local-first)

6. Backup/DR

ไม่มีข้อมูลถาวรให้สำรอง; ความต่อเนื่องอยู่ที่ไฟล์ input ของผู้ใช้ + audit package (input/config fingerprint) ซึ่งใช้ rerun ซ้ำได้ ถ้าจะมี persistence ต้องกำหนด retention, backup และ replay ก่อน (`deploy/README.md`)

การอนุมัติ

บทบาท	สถานะ	วันที่	ลงนาม
Solution Architect	รอพิจารณา	—	_
Security reviewer	รอพิจารณา	—	_

แหล่งข้อมูล

- `apps/api/src/migration_validation_api/server.py`, `apps/api/src/migration_validation_api/cli.py`
- `connectors/file-input/src/migration_input/input_contract.py`, `packages/reconciliation-core/src/reconciliation_core/fuzzy.py`
- `packages/audit/src/migration_audit/package.py`, `packages/privacy/src/migration_privacy/redaction.py`
- `evals/tests/*.py`, `docs/UPGRADE-PLAN.md`, `deploy/README.md`, `README.md`
- `(solo-empire) opportunities/business/cli-tools/MIGRATION-VALIDATION-WORKBENCH-PRODUCT-BRIEF.md`